

Security in the Cloud TASK – 5

- 1. Create a new IAM user in your chosen cloud provider (AWS, Azure, or GCP) named 'foodieAppTester' and assign only the permissions needed to list storage buckets or containers, but not to create or delete them.

Hint: Use built-in roles like 'Storage Viewer' or create a custom policy with only 'list' actions.**

Ans :

- Sign in to the AWS Management Console.
 - Open the IAM (Identity and Access Management) service.
 - In the left navigation pane, select Users.
 - Click Create user.
 - {
 - "Version": "2012-10-17",
 - "Statement": [- {
 - "Sid": "ListStorageBucketsOnly",
 - "Effect": "Allow",
 - "Action": [- "s3:ListAllMyBuckets",
 - "s3:ListBucket"
 -],
 - "Resource": "*"
- }
-]
- }

- Click Create policy.
 - Return to the user creation page and refresh the policy list.
- 2. Audit the permissions of an existing IAM user or role in your cloud account and identify at least two permissions that are broader than necessary for a Zomato-style food delivery app backend (for example, full access to all services instead of just database and storage read/write).**

Ans :

```
{  
  "Version": "2012-10-17",  
  "Statement": [  
    {  
      "Effect": "Allow",  
      "Action": "*",  
      "Resource": "*"   
    }  
  ]  
}
```

- 3. Modify the overly broad permissions you found in the previous task by editing the policy to restrict access only to the required services and actions (for example, allow only read/write to the food menu database and order storage, deny all other actions).**

Ans :

```
{  
  "Version": "2012-10-17",  
  "Statement": [  

```

```
{
  "Sid": "FoodMenuDatabaseAccess",
  "Effect": "Allow",
  "Action": [
    "dynamodb:GetItem",
    "dynamodb:PutItem",
    "dynamodb:UpdateItem",
    "dynamodb:Query",
    "dynamodb:Scan"
  ],
  "Resource": "arn:aws:dynamodb:*:*:table/FoodMenu"
},
{
  "Sid": "OrderStorageAccess",
  "Effect": "Allow",
  "Action": [
    "dynamodb:GetItem",
    "dynamodb:PutItem",
    "dynamodb:UpdateItem",
    "dynamodb:Query"
  ],
  "Resource": "arn:aws:dynamodb:*:*:table/Orders"
},
{
```

```
"Sid": "OrderImagesStorageAccess",
"Effect": "Allow",
"Action": [
    "s3:GetObject",
    "s3:PutObject"
],
"Resource": "arn:aws:s3:::food-order-images/*"
},
{
    "Sid": "DenyUnnecessaryActions",
    "Effect": "Deny",
    "Action": [
        "iam:*",
        "ec2:*",
        "s3:DeleteObject",
        "s3:DeleteBucket",
        "dynamodb:DeleteTable",
        "dynamodb:DeleteItem"
    ],
    "Resource": "*"
}
]
```

- 4. Use ChatGPT or Copilot to generate a least-privilege IAM policy JSON for a user who only needs to upload profile pictures to a 'user-profile-pics' storage bucket. Review the generated policy and apply it to a test user.

Hint: Ask the AI tool to explain each permission in the policy so you understand what it allows.**

Ans :

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "AllowProfilePictureUploads",
      "Effect": "Allow",
      "Action": [
        "s3:PutObject"
      ],
      "Resource": "arn:aws:s3:::user-profile-pics/*"
    }
  ]
}
```

- 5. Prepare a 3-minute presentation or a 1-page document showing your IAM user/role configurations, the before-and-after policy changes, and suggest one improvement to further tighten security for a Flipkart-style cloud backend.**

Ans :

- IAM User/Role Configuration Overview
- {
- "Version": "2012-10-17",
- "Statement": [
- {
 - "Effect": "Allow",
 - "Action": "*",
 - "Resource": "*"
- }
-]
- }
- After Changes: Least-Privilege Policy
- {
- "Version": "2012-10-17",
- "Statement": [
- {
 - "Sid": "OrderDatabaseAccess",
 - "Effect": "Allow",
 - "Action": [
 - "dynamodb:GetItem",
 - "dynamodb:PutItem",
 - "dynamodb:UpdateItem",
 - "dynamodb:Query"
 -],
 - "Resource": "arn:aws:dynamodb:*:*:table/Orders"
- },
- {
 - "Sid": "ProductImageStorageAccess",
 - "Effect": "Allow",
 - "Action": [
 - "s3:GetObject",
 - "s3:PutObject"

-],
 - "Resource": "arn:aws:s3:::product-images/*"
- }
-]
- }
 - IAM Configuration Summary
- IAM Role: eCommerceBackendRole
- Allowed Actions:
- Read and update order records.
- Store and retrieve product images.
- Restricted Actions:
- No IAM user management.
- No EC2 administration.
- No database deletion.
- No bucket deletion.
- No access to unrelated AWS services.